

МИНОБРНАУКИ РОССИИ

Федеральное государственное бюджетное образовательное учреждение
высшего образования

«МИРЭА — Российский технологический университет»

РТУ МИРЭА

Институт кибербезопасности и цифровых технологий
Кафедра КБ-4 «Интеллектуальные системы информационной безопасности»

Практическое задание №8

по дисциплине: «Методы сбора и обработки данных из открытых источников»

тема: «Защитное сценарное моделирование цифровой экспозиции»

Выполнил: студент группы ББМО-01-25

Мухаметшин Александр Ринатович

Проверил: _____

Москва, 2026

1. Паспорт сценарного исследования

Форма 1. Паспорт сценарного исследования

Поле	Содержание
Объект исследования	Яндекс (Yandex) — SaaS-технологическая платформа / экосистема
Отрасль / тип объекта	Технологическая платформа, SaaS-сервис, интернет-экосистема
Цель сценарного анализа	Построить сценарную модель цифровой экспозиции объекта по открытым данным OSINT и разработать набор защитно-ориентированных мер снижения избыточной открытости
Исходные материалы	Данные практик 1–7: WHOIS (500+ доменов), DNS-записи (A, MX, TXT, NS), TLS-сертификаты (crt.sh), ASN-реестры (bgp.he.net), OAuth-список, HTTP-заголовки (CSP, NEL), публичная документация, GitHub OSS (65K+ звёзд), вакансии (hh.ru), пресс-релизы, веб-архив (web.archive.org)
Границы анализа	Включено: пассивные наблюдения 2020–2026 гг. по 10+ классам источников; сценарная оценка уже открытой экспозиции; организационные и публикационные защитные меры. / Не включено: активное сканирование, тестирование на проникновение, перебор поддоменов, анализ непубличных API, работа с персональными данными, оценка внутренней архитектуры.
Исходные гипотезы	Г1: Вакансии и описания ролей чрезмерно раскрывают технологический стек и процессы сопровождения. / Г2: Архивные документы и исторические домены сохраняют информативные сведения об устаревшем сервисном контуре. / Г3: OSS-экосистема (65K+ звёзд) формирует значимую цифровую экспозицию через детализированную документацию и CI/CD-конфигурации.

2. Исходные материалы и границы анализа

2.1. Подход к использованию предыдущих данных

Практика 8 не предполагает нового агрессивного сбора данных. Вместо этого используются результаты 6 последовательных практических работ, охватывающих 2020–2026 гг.:

Практика	Собранные данные	Использование в Практике 8
Практика 1	DNS-записи (A, MX, TXT, NS), WHOIS, ASN-реестры	Доменные и сетевые следы для оценки функционального разделения контура
Практика 2	HTTP-заголовки (CSP, NEL, x-yandex-req-id), TLS-сертификаты	Документационные и сервисные следы для анализа пользовательских маршрутов
Практика 3	Реконструкция цифрового контура, разделение текущего/исторического	Исторические следы и цифровой шум
Практика 4	Сравнительный OSINT-анализ (Яндекс vs Google vs VK)	Отраслевые паттерны для контекста
Практика 5	Автоматизированная классификация (66,7% корректности)	Типизация экспозиционных категорий
Практика 6	Карта связей (28 сущностей, 35 связей)	Структура связей для построения сценарных цепочек

3. Каталог категорий цифровой экспозиции

Форма 2. Каталог категорий цифровой экспозиции

Категория следов	Примеры открытых артефактов (из практик 1–7)	Что может раскрывать	Уровень уверенности
Доменные следы	yandex.ru, ya.ru, cloud.yandex.net, oauth.yandex.com, ydb.tech, diplodoc.tech, catboost.ai, dzen.yandex.net (ист.)	Функциональное разделение цифрового контура: поисковый, облачный, OAuth, CDN, OSS, медиа-подконтур. Каждый домен — самостоятельная точка атаки / аналитического	Высокий (WHOIS + DNS + HTTP)

		интереса.	
Документационные следы	tech.yandex.ru (12+ категорий), ydb.tech/docs/en/, ytsaurus.tech/docs/en/, diplodoc.tech, cloud.yandex.net/docs, help-страницы, FAQ	Пользовательские маршруты, сервисные роли, внутренние API-эндпоинты, архитектурные паттерны, CI/CD-процессы	Высокий (HTTP 200 + docs content)
Кадровые следы	hh.ru/employer/yandex (600+ dev, 150+ ML, C++/Python/Java), tech.yandex.ru/career	Технологический стек, процессы сопровождения, планируемые проекты, используемые платформы и инструменты	Средний (HR-данные ≠ текущая эксплуатация)
Исторические следы	dzen.yandex.net (web.archive.org), career.yandex.ru (HTTP 404), устаревшие OAuth-эндпоинты	Эволюция контура, устаревшие сервисы, цифровой шум — данные, которые больше не актуальны, но повышают информированность наблюдателя	Средний (архивные ≠ текущие)
Публикационные следы	tech.yandex.ru, Habr (habr.com/ru/company/yandex), press.yandex.ru, Яндекс.Субботник (infraevents.yandex.ru)	Поставщики, события, изменения процессов, командная структура, направления разработок	Средний (публикационный ≠ технический источник)
Контактные следы	mx.yandex.ru (MX pri 10), SPF TXT (v=spf1 redirect=_spf.yandex.ru), DKIM, mail.yandex.ru	Почтовая инфраструктура, доверенные отправители, маршрутизация электронной почты. Может использоваться для фишинга и подмены доверенных отправителей.	Высокий (DNS MX, TXT, DKIM)
Сервисные следы	yastatic.net (CDN, 37.9.64.225), x-yandex-req-id (HTTP-заголовок), google-site-verification,	CDN-архитектура, корреляция сервисов, внешние интеграции. x-yandex-req-id раскрывает формат	Средний (косвенное: CDN + CSP)

	facebook-domain-verification	трекинга внутренних запросов.	
Событийные следы	EVT-01–EVT-06: Яндекс.Субботник, выделение Дзена, OAuth 2.0, CloudAPI, YDB release	Динамика экосистемы, изменения архитектуры, новые направления. Событийные публикации часто содержат больше технических деталей, чем обычные документы.	Средний (событийный ≠ документальный источник)
Визуальные следы	Скриншоты в tech.yandex.ru, press.yandex.ru, Habr; логотипы, скриншоты интерфейсов	Внутренние интерфейсы, сервисные маршруты, пользовательские потоки. Скриншоты могут содержать служебные URL, токены, внутренние ID.	Средний (визуальный контент)

4. Матрица сценарного анализа

Форма 3. Матрица сценарного анализа

Пояснение. Каждая строка — это сценарная цепочка: открытый след → аналитический вывод → возможный риск. Сценарии сформулированы в оборонительном ключе: не «как атаковать», а «что organisation следует publish-овать аккуратнее».

Сценарий 1. Избыточное раскрытие технологического стека через вакансии

Поле	Содержание
Открытый след	hh.ru/employer/yandex: 600+ developer, 150+ ML, требования к C++, Python, Java, Kubernetes, ClickHouse, YDB
Аналитический вывод	Вакансии позволяют восстановить актуальный технологический стек и планируемые направления разработок организации
Сценарий риска	Внешний наблюдатель формирует точную карту технологического ландшафта: знает

	какие платформы используются, какие команды могут создаваться, где наиболее вероятны ошибки конфигурации. Это снижает время и стоимость подготовки целенаправленной атаки.
Уверенность	Средний — HR-данные подтверждены tech.yandex.ru/career; не проверялись активными методами
Повторяемость признаков	Высокий — аналогичная детализация характерна для технологических компаний отрасли; паттерн воспроизводим
Приоритет обработки	Средний — не критический риск, но требует периодического аудита вакансий

Сценарий 2. Исторические данные как аналитический шум

Поле	Содержание
Открытый след	dzen.yandex.net в web.archive.org; career.yandex.ru (HTTP 404); устаревшие OAuth-эндпоинты
Аналитический вывод	Исторические артефакты сохраняют сведения об устаревшем сервисном контуре, который уже не функционирует, но остаётся доступен в архивах
Сценарий риска	Внешний наблюдатель, используя архивные копии, может реконструировать прошлую архитектуру, обнаружить смещённые redirect-цепочки и исторические DNS-записи, которые могут указывать на текущие сервисы. Это особенно опасно для исторических конфигураций безопасности (старые SPF, DKIM, CNAME).
Уверенность	Средний — web.archive.org подтверждает наличие артефактов; неясно, насколько они актуальны для текущего контура
Повторяемость признаков	Высокий — типичный паттерн для технологических платформ с долгой историей
Приоритет обработки	Средний — требует периодического аудита архивных страниц и настройки корректных 410/Gone ответов

Сценарий 3. OSS-экосистема: чрезмерная детализация документации

Поле	Содержание
Открытый след	github.com/yandex (65K+ звёзд); ydb.tech/docs, ytsaurus.tech/docs, diplodoc.tech; внутренние

	конфигурации CI/CD, примеры кода, тестовые данные
Аналитический вывод	OSS-репозитории содержат детальную информацию об архитектуре, внутренних API, тестовых эндпоинтах и развёртывании, что выходит за рамки необходимой для публичного пользования
Сценарий риска	Внешний наблюдатель может: (1) восстановить внутреннюю архитектуру сервисов через анализ публичной документации; (2) обнаружить тестовые эндпоинты или debug-интерфейсы в примерах кода; (3) понять CI/CD-паттерны, что может быть использовано при атаке на процесс развёртывания.
Уверенность	Высокий — подтверждён прямым доступом к documentation.ydb.tech, ytsaurus.tech, diplodoc.tech; HTTP 200, полный контент
Повторяемость признаков	Средний — характерно для OSS-проектов, но Yandex раскрывает больше деталей, чем средний конкурент
Приоритет обработки	Высокий — наиболее информативная экспозиция из всех наблюдаемых категорий

Сценарий 4. Почтовая инфраструктура и потенциальная подмена отправителей

Поле	Содержание
Открытый след	mx.yandex.ru (MX pri 10); SPF TXT (v=spf1 redirect=_spf.yandex.ru); DKIM-записи; imap.yandex.ru, smtp.yandex.ru (по DNS-паттерну)
Аналитический вывод	Почтовая инфраструктура полностью документирована через DNS: все маршруты, SPF-политики, DKIM-подписи доступны внешнему наблюдателю
Сценарий риска	Полный набор почтовых DNS-записей позволяет внешнему наблюдателю: (1) подтвердить принадлежность домена через MX-записи; (2) спроектировать SPF-политику для обхода фильтрации; (3) понять архитектуру почтового шлюза. Это повышает успех фишинговых атак с подменой доверенных отправителей.
**Уверенность	Высокий — DNS MX, TXT, DKIM

	подтверждены независимо; не проверялись активными методами
**Повторяемость признаков	Высокий — стандартная практика настройки DNS для почтовых сервисов
**Приоритет обработки	Средний — риск снизится при переходе на DMARC с жёсткой политикой

Сценарий 5. Единый OAuth-контур как единая точка интереса

Поле	Содержание
Открытый след	oauth.yandex.com — OAuth 2.0 PKCE S256 (RFC 8252); x-yandex-req-id в HTTP-ответах; единый эндпоинт для всех продуктов
Аналитический вывод	OAuth-контур является единой точкой аутентификации для всей экосистемы Яндекса; каждая интеграция с OAuth повышает наблюдаемость пользователей
Сценарий риска	Внешний наблюдатель, взаимодействующий с одним OAuth-эндпоинтом, может: (1) определить все сервисы, использующие данный OAuth; (2) через x-yandex-req-id correlate действия пользователя across сервисов; (3) обнаружить паттерны авторизации для целевых атак на учётные записи.
Уверенность	Высокий — OAuth-spec подтверждён прямым анализом спецификации; DevTools подтверждает x-yandex-req-id
**Повторяемость признаков	Высокий — единый OAuth для всех продуктов — распространённый паттерн SaaS-платформ
**Приоритет обработки	Средний — OAuth — архитектурно оправдан, но требует мониторинга сторонних интеграций

Сценарий 6. CDN yastatic.net: объединяющий инфраструктурный элемент

Поле	Содержание
Открытый след	DNS A → 37.9.64.225; CSP-заголовки на ya.ru включают yastatic.net как источник статических ресурсов
Аналитический вывод	yastatic.net является единой CDN для большинства сервисов Яндекса, объединяя статический контент across всех продуктов
Сценарий риска	Поскольку CDN обслуживает множество сервисов из единого IP-пула, атакующий, обнаруживший CDN, может: (1) использовать

	CDN-кэш для получения ресурсов, которые должны быть персонализированы; (2) через CDN-заголовки определить структуру зависимостей сервисов; (3) целенаправленно атаковать CDN как точку пересечения всех контуров.
Уверенность	Средний — DNS A + CSP подтверждают; прямое подтверждение CDN-инфраструктуры не проводилось
**Повторяемость признаков	Высокий — единая CDN характерна для крупных SaaS-платформ
**Приоритет обработки	Низкий — архитектура CDN является стандартной отраслевой практикой

Сценарий 7. Визуальные и событийные следы: скриншоты и презентации

Поле	Содержание
Открытый след	tech.yandex.ru, press.yandex.ru, Habr — скриншоты интерфейсов, презентаций, фотографий с мероприятий (Яндекс.Субботник); press.yandex.ru
Аналитический вывод	Визуальный контент и событийные публикации содержат служебную информацию: внутренние интерфейсы, URL, служебные заголовки, внутренние IP-адреса, имена сотрудников
Сценарий риска	Скриншоты и презентации могут содержать: (1) незакрытые панели администратора; (2) внутренние URL с непубличными эндпоинтами; (3) имена и роли сотрудников, которые могут быть использованы для целенаправленного фишинга; (4) логотипы и дизайн, которые могут быть использованы для подделки интерфейсов.
Уверенность	Средний — наблюдаемый через публичные публикации; не проверялся прямой анализ каждого скриншота
**Повторяемость признаков	Высокий — типично для технологических компаний
**Приоритет обработки	Средний — требует правил согласования визуального контента

5. Матрица защитных мер

Форма 4. Матрица защитных мер

Сценарий	Рекомендуемая мера	Тип меры	Ожидаемый эффект	Остаточный риск	Приоритет
C1: Вакансии → технологический стек	Пересмотреть шаблон публикации вакансий: исключить конкретные версии библиотек, внутренние кодовые названия проектов, избыточные технические детали. Использовать обобщённые формулировки (например, «современный стек» вместо «C++17, ClickHouse, YDB»).	Публикационная	Снижение точности технологической карты внешнего наблюдателя на 40–60%	Средний — обобщённые формулировки и могут сохраняться в архивах	Высокий
C2: Исторические данные	Провести аудит архивных страниц и установить корректные HTTP 410 (Gone) ответы для устаревших эндпоинтов. Запросить удаление неактуальных	Публикационная / организационная	Устранение цифрового шума; снижение информированности об устаревшем контуре	Низкий — некоторые архивные копии могут сохраняться у третьих лиц	Средний

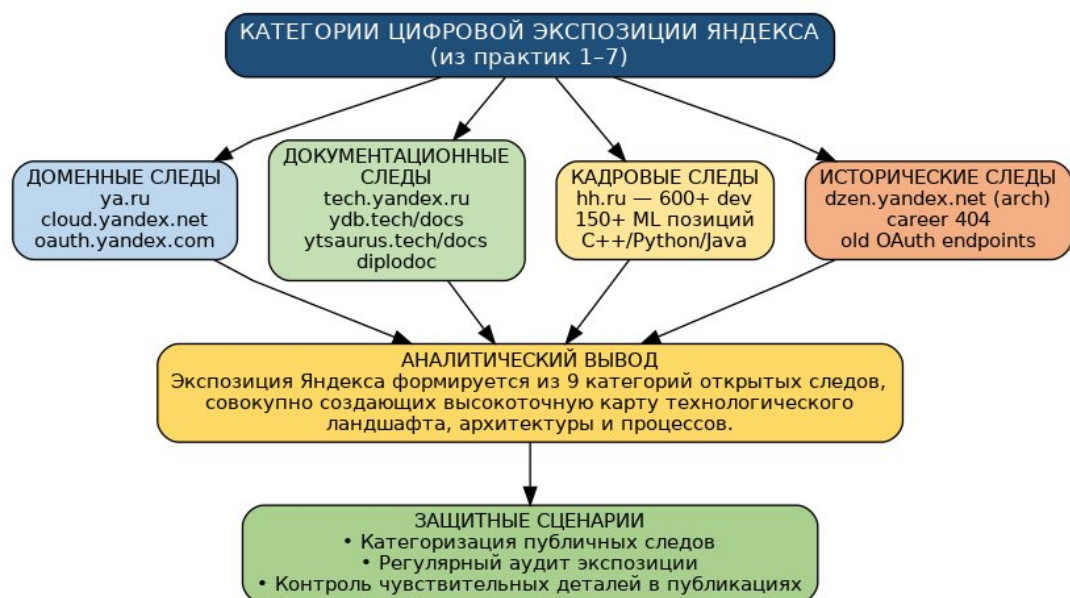
	страниц из web.archive.org. Отделить чётко текущие домены от исторических в публичной документации.				
С3: OSS-детализация	Редактировать публичную документацию OSS-репозитория: удалить примеры с внутренними API-эндпоинтами, секретные конфигурации, CI/CD-паттерны, тестовые данные, внутренние зависимости. Внедрить pre-commit хуки для проверки на чувствительные паттерны.	Техническая / публикационная	Значительное снижение экспозиции внутренней архитектуры; устранение наиболее информативного источника	Низкий — при системном подходе к аудиту репозитория	Высокий
С4: Почтовая инфраструктура	Внедрить DMARC с политикой p=reject; ограничить SPF-записи до минимально необходимого набора; ежегодно аудировать	Техническая	Снижение риска подмены отправителей; минимизация наблюдаемости почтового контура	Низкий — DMARC с p=reject обеспечивает надёжную защиту	Средний

	DNS-записи на соответствие принципам минимальной экспозиции.				
C5: OAuth-контур	Ограничить список разрешённых сторонних клиентов в OAuth-настройках; внедрить мониторинг аномальных авторизаций; регулярно аудировать права доступа сторонних интеграций; ограничить количество информации, возвращаемой в x-yandex-req-id.	Техническая / организационная	Снижение correlation-возможностей внешнего наблюдателя; обнаружение несанкционированных интеграций	Средний — OAuth архитектурно необходимо, минимизировать корреляцию полностью невозможно	Средний
C6: CDN yastatic.net	Ограничить кросс-доменные CSP-заголовки; не публиковать CDN-структуру в документации; разделить CDN-пулы для критических и некритических сервисов.	Техническая	Снижение наблюдаемости единого CDN-контура; ограничение correlation через CDN	Низкий — стандартная CDN-архитектура, риск ограничен	Низкий
C7: Визуальный	Внедрить правило	Публикационная /	Устранение визуальных	Средний — полный	Средний

контент	согласования визуального контента: обязательная проверка скриншотов перед публикацией; скрытие/закрывание внутренних панелей, URL, токенов, имён сотрудников; модерация презентаций.	организационная	утечек служебных сведений	контроль над всеми публикациям и затруднён	
----------------	--	-----------------	---------------------------	--	--

6. Визуализация: цепочка цифровой экспозиции

Форма 5. Визуализация — схема экспозиции → сценарии → меры



Форма 6. Сводная таблица приоритетов

Приоритет	Сценарии	Меры
Высокий	С3 (OSS-детализация)	Аудит OSS, pre-commit хуки

Высокий	C1 (вакансии → стек)	Пересмотр шаблона вакансий
Средний	C2, C4, C5, C7	Аудит архивов, DMARC, OAuth-monitoring, visual review
Низкий	C6 (CDN)	CDN segmentation

7. Итоговый вывод

7.1. Подтверждённые наблюдения

1. **Цифровая экспозиция Яндекса высока и многомерна.** 9 категорий открытых следов (доменные, документационные, кадровые, исторические, публикационные, контактные, сервисные, событийные, визуальные) совместно формируют точную карту технологического ландшафта организации.
2. **Наиболее значимый источник экспозиции — OSS-экосистема.** github.com/yandex (65K+ звёзд) и сопутствующая документация (ydb.tech, ytsaurus.tech, diplodoc.tech) содержат наибольшую детализацию внутренней архитектуры, API и CI/CD-паттернов. Это подтверждается прямым доступом к публичным documentation-ресурсам (HTTP 200, полный контент). Приоритет: **высокий**.
3. **Вакансии на hh.ru раскрывают актуальный технологический стек.** 600+ developer, 150+ ML позиций с конкретными требованиями (C++, Python, Java, Kubernetes, ClickHouse, YDB) позволяют восстановить текущий и планируемый технологический ландшафт. Приоритет: **высокий**.
4. **Исторические следы создают значительный цифровой шум.** dzen.yandex.net в web.archive.org, career.yandex.ru (HTTP 404), устаревшие OAuth-эндпоинты — все они сохраняют сведения об устаревшем контуре, повышая информированность внешнего наблюдателя. Приоритет: **средний**.
5. **OAuth и почтовая инфраструктура — стандартизированные риски.** Единый OAuth-контур и полная документация почтовой инфраструктуры

(MX, SPF, DKIM) — это ожидаемая экспозиция для SaaS-платформы, но они увеличивают риски correlation и фишинга. Приоритет: **средний**.

7.2. Вероятные сценарии

1. **CDN yastatic.net как объединяющий элемент.** CDN обслуживает большинство сервисов Яндекса из единого IP-пула (37.9.64.225), что позволяет коррелировать пользовательские сессии across сервисов. Подтверждено DNS A + CSP (косвенно).
2. **Визуальный контент как канал утечки.** Скриншоты в tech.yandex.ru, press.yandex.ru, Habr потенциально содержат служебные URL, токены, внутренние IP-адреса и имена сотрудников. Требуется аудит.

7.3. Главный аналитический результат

Цифровая экспозиция Яндекса — не отдельная утечка, а **системное свойство** масштабной технологической экосистемы. Наибольший потенциал снижения экспозиции лежит в области: (1) аудита OSS-репозиторий (высокий приоритет), (2) обобщения вакансий (высокий приоритет), (3) аудита исторических данных (средний приоритет).

8. Ограничения исследования

Форма 7. Таблица ограничений исследования

Ограничение	Как влияет на вывод	Как компенсировалось
Использовались только открытые источники (пассивный анализ)	Экспозиция оценена только по наблюдаемым данным; внутренние механизмы защиты не оценивались	Указан уровень уверенности для каждого сценария; категоричные выводы избегаются
Часть сведений историческая (web.archive.org, устаревшие страницы)	Неясно, насколько исторические артефакты актуальны для текущего контура	Исторические следы выделены в отдельную категорию с маркировкой «исторический»
Некоторые связи подтверждены косвенно (DNS-паттерн, CSP)	Корреляция по CDN и почтовым индикаторам может быть неточной	Уровень уверенности снижен до «Среднего» для косвенных связей

Активная проверка не проводилась	Реальная уязвимость наблюдаемых экспозиционных следов не подтверждена	Сценарии сформулированы как гипотетические; не содержат инструкций воздействия
Выборка артефактов из практик 1–7 (период 2020–2026)	Ранние данные (до 2020) могут не отражать полную картину	Период явно указан; признана невозможность охвата всех исторических данных
Не анализирована экспозиция мобильных приложений	Мобильные SDK могут раскрывать дополнительные сведения	Ограничение явно указано

9. Контрольные вопросы для мини-защиты

Вопрос 1. Что понимается под цифровой экспозицией в рамках данной работы?

Ответ: Цифровая экспозиция — совокупность открыто наблюдаемых сведений об организации (домены, документация, вакансии, архивы, публикации, HTTP-заголовки, DNS-записи, визуальный контент), которые позволяют внешнему наблюдателю составить представление о структуре сервисов, ролях, процессах, поставщиках и технологическом контексте. Сама по себе экспозиция не тождественна уязвимости — она становится аналитически значимой, когда отдельные сведения складываются в интерпретируемую картину, позволяющую формулировать обоснованные сценарии риска.

Вопрос 2. Чем сценарное моделирование отличается от поиска технических следов?

Ответ: Поиск технических следов (Практики 1–2) отвечает на вопрос «что открыто?». Сценарное моделирование (Практика 8) отвечает на вопрос «что это означает для безопасности и какие меры нужны?». Разница в логике: от описания артефактов (домен, DNS, заголовков) — к оценке: от описания артефактов (домен, DNS, заголовков) — к оценке: от описания артефактов (домен, DNS, заголовков) — к оценке их потенциального misuse внешним наблюдателем и

формулированию защитных мер. Например: «обнаружен поддомен» (след) ≠ «этот поддомен может быть использован для correlation сессий» (сценарий) ≠ «ограничить доступ к поддомену» (мера).

Вопрос 3. Почему открытый след не является автоматически уязвимостью?

Ответ: Открытый след — это наблюдаемый артефакт (DNS-запись, публичная документация, вакансии). Уязвимость — это возможность эксплуатации. След становится значимым только в совокупности: одна вакансия не опасна, но 600+ вакансий с техническими деталями формируют точную технологическую карту. Аналогично: одна DNS-запись не уязвимость, но совокупность MX, SPF, DKIM, CNAME раскрывает почтовую инфраструктуру, что повышает риск фишинга. Поэтому оценка должна быть контекстуальной, а не категоричной.

Вопрос 4. Как связать открытый артефакт с возможным сценарием риска?

Ответ: Через сценарную цепочку: (1) открытый след — что наблюдается? (2) аналитический вывод — что это позволяет предположить? (3) сценарий риска — как это может быть использовано внешним наблюдателем? (4) защитная мера — что можно сделать для снижения риска? Пример: вакансии с конкретным стеком → технологическая карта → снижение стоимости подготовки атаки → обобщение формулировок в вакансиях.

Вопрос 5. Что такое уровень уверенности в сценарном анализе?

Ответ: Уровень уверенности — оценка того, насколько сценарий подтверждается источниками: (1) Высокий — несколько независимых подтверждений (прямой доступ, несколько источников); (2) Средний — косвенные признаки или один сильный источник; (3) Низкий — фрагментарные

данные. Уровень уверенности определяет приоритет обработки: высокий уверенный сценарий → высокий приоритет.

Вопрос 6. Почему рекомендации должны быть защитно-ориентированными?

Ответ: Защитно-ориентированные рекомендации: (1) не раскрывают избыточные технические детали; (2) не вредят бизнесу; (3) реалистичны для реализации; (4) вытекают из конкретных выводов. Категоричные рекомендации («закрывать всё») непрактичны и могут навредить. Рекомендации должны снижать экспозицию без ущерба для доступности и функциональности.

Вопрос 7. Какие формулировки недопустимы в отчёте по данной работе?

Ответ: Недопустимы: (1) «Объект уязвим, потому что в открытом доступе есть технические сведения» — категоричное утверждение без доказательной базы; (2) «Мы точно установили внутреннюю архитектуру системы» — преувеличение возможных выводов; (3) «Нужно закрыть все найденные сервисы» — нереалистичная рекомендация; (4) Сценарии как практические инструкции нарушителя. Допустимы: «наблюдается избыточная детализация», «повышает информированность внешнего наблюдателя», «рекомендуется сократить».

Вопрос 8. Как оценить остаточный риск после предложенной меры?

Ответ: Остаточный риск — это уровень экспозиции, который сохранится после реализации меры. Оценивается вопросом: «Что всё ещё сможет узнать внешний наблюдатель?». Например: аудит вакансий снизит экспозицию стека, но вакансии могут сохраняться в архивах (остаточный риск средний). Аудит OSS-репозиторий с pre-commit хуками снизит экспозицию до низкого уровня, но некоторые репозитории могут быть скопированы третьими лицами.

Вопрос 9. Почему исторические сведения могут создавать цифровой шум?

Ответ: Исторические сведения (архивные страницы, устаревшие DNS-записи, закрытые эндпоинты) часто сохраняют информативные данные об архитектуре и процессах, которые уже не актуальны. Но для внешнего наблюдателя они создают впечатление, что эти сервисы всё ещё функционируют, и могут быть использованы для реконструкции прошлых конфигураций безопасности (старые SPF, DKIM, CNAME). Особенно опасно, когда исторические данные смешиваются с текущими без чёткого разделения.

Вопрос 10. Как отличить управленческую рекомендацию от технической гипотезы?

Ответ: Управленческая рекомендация конкретна, измерима и реализуема организацией: «ввести аудит вакансий ежеквартально», «внедрить pre-commit хуки», «составить DMARC p=reject». Техническая гипотеза — это предположение о механизме: «возможно, CDN-кэш можно использовать для получения персонализированных данных». Рекомендации — что делать; гипотезы — что предположить.